VALCRÉA

Conception d’un réseau sécurisé pour une PME

DOSSIER DE CONCEPTION | TP01 • PARTIE 1

Audit · besoins · architecture · sécurité · résilience · budget

Référentiel	Périmètre	Statut
MAIN PROGRESSION v1.9.0	Lyon, Bordeaux, nomades ; Nantes réservé	Document soumis à revue MAIN

Édition : 7 novembre 2026 • Mode SOLO • Catalogue fictif officiel du TP01

Note de lecture : ce dossier formalise une conception cible. Les équipements supplémentaires, services, tests et options HA ne sont pas présentés comme déployés.

Table des matières

1. Contexte et objectifs

2. Audit de l’existant et risques prioritaires

3. Cahier des charges et critères de recette

4. Architecture logique et schéma réseau

5. Plan d’adressage et segmentation VLAN

6. Matrice de flux et politique de sécurité

7. Services, résilience, sauvegarde et évolutivité

8. Budget CAPEX/OPEX/TCO sur cinq ans

9. Limites, hypothèses et décisions en attente

10. Conclusion et stratégie de déploiement

Annexe A. Synthèse de l’audit et traçabilité

Annexe B. Référentiels de flux, prix et sources

Convention de gouvernance

Mention	Signification
SOURCE-REQUIRED	Prescription du TP01.
PROJECT-DECIDED	Décision acceptée par MAIN PROGRESSION.
PROPOSED	Option de conception ou d’investissement, non approuvée.
OBSERVED-REPORTED	Élément rapporté par une étape antérieure, non revérifié ici.
PENDING	Arbitrage ou donnée non encore obtenu.

Les anciennes pièces E02–E08 restent intactes. Le présent document est une synthèse de conception et non une preuve de mise en service.

1. Contexte et objectifs

Valcréa conçoit, fabrique et commercialise du mobilier de bureau éco-conçu. L'entreprise emploie 48 personnes : 38 à Lyon (siège et atelier), 6 à Bordeaux (showroom) et 4 itinérants. Elle prévoit 15 recrutements en trois ans, soit un effectif cible de 63 salariés. Le chiffre d'affaires présenté est de 7,2 M€ (TP01, Annexe A, p.16–17).

1.1 Périmètre

- Siège Lyon : utilisateurs, bureau d'études, atelier CNC, identité, fichiers, accès SaaS et supervision.
- Bordeaux : salariés, Wi-Fi visiteurs et accès aux ressources Lyon via une liaison sécurisée projetée.
- Nomades : accès VPN aux ressources explicitement autorisées, sans RDP public.
- Nantes : bloc 10.30.0.0/16 réservé, sans agence ni service actuellement déployés.

1.2 Objectifs quantifiés

Indicateur	Objectif	Nature
Investissement initial	≤ 30 000 € HT	SOURCE-REQUIRED
Fonctionnement annuel	≤ 6 000 € HT/an	SOURCE-REQUIRED
Fichiers : RTO	≤ 4 heures	SOURCE-REQUIRED / non testé
Fichiers : RPO	≤ 24 heures	SOURCE-REQUIRED / non testé
Effectif	48 → 63 à trois ans	SOURCE-REQUIRED

1.3 Exigences transverses

Défense en profondeur, refus par défaut, séparation des tâches, administration nominative, confidentialité des données RH, exploitation praticable par un technicien à temps partiel, accessibilité aux personnes utilisant un lecteur d'écran, maîtrise de l'empreinte énergétique et documentation maintenable. Le RGPD, les recommandations CNIL/ANSSI, la loi REEN et le RGAA sont retenus comme références de conception selon le TP ; leur applicabilité juridique détaillée doit être vérifiée.

2. Audit de l’existant et risques prioritaires

L’audit E02 a été VALIDATED documentairement par MAIN : 20 constats, dont 12 techniques et 8 organisationnels. Les faits proviennent du dossier fictif de l’Annexe A ; aucun scan du réseau réel n’est revendiqué.

Priorité	Constat	Risque / réponse de conception
CRITIQUE	RDP TCP 3389 exposé depuis Internet	Compromission ; suppression de publication WAN, accès VPN uniquement.
ÉLEVÉE	Réseau à plat 192.168.1.0/24	Propagation latérale ; VLAN et filtrage interzones.
ÉLEVÉE	Windows Server 2012 R2 unique, sans UPS	Indisponibilité ; renouvellement, sauvegardes, UPS et PRA.
ÉLEVÉE	NAS local, aucune copie distante ni restauration éprouvée	Rançongiciel/incendie ; externalisation et exercices PRA.
ÉLEVÉE	Comptes partagés/anciens actifs, droits RH inadéquats	Accès illégitimes ; administration nominative, AGDLP/NTFS.
MOYENNE	Wi-Fi visiteurs partagé avec le réseau interne	Intrusion ; VLAN INVITES isolé.
MOYENNE	Supervision et registre d’équipements absents	Détection tardive ; Zabbix et inventaire.

2.1 Incident de référence

Une pièce jointe malveillante a entraîné le chiffrement d’une partie du partage commun ; la restauration NAS a occasionné deux jours de travail perdus (TP01, Annexe A). La conception retient donc la capacité de restaurer les fichiers comme un résultat à démontrer, et non simplement l’existence de copies de sauvegarde.

2.2 Limite

Cette synthèse présente les risques déterminants, pas l’intégralité des 20 lignes E02. Le classeur original E02 accepté par MAIN demeure la preuve détaillée de l’audit ; il n’a pas été accessible sous forme de fichier autonome dans cette session.

3. Cahier des charges et critères de recette

Le cahier E03 regroupe cinq rubriques et 24 exigences : F01–F09 (9 fonctionnelles), NF01–NF07 (7 non fonctionnelles) et C01–C08 (8 contraintes), ainsi que 13 critères R01–R13. Le tableau suivant reprend les mesures déterminantes sans requalifier les tests comme exécutés.

Référence	Exigence / résultat attendu
F01, F06	Fichiers accessibles aux rôles autorisés ; RH réservée à direction et comptabilité ; Production lecture seule pour Atelier.
F02 / R01	VPN autorisé opérationnel ; 0 service RDP TCP 3389 exposé au WAN.
F03 / R02	Invités : HTTPS Internet OK ; 0 port de serveur interne accessible.
F04 / R03	Atelier : accès Production autorisé ; 0 accès Internet.
F07 / R09	Trois comptes sortants désactivés ; 0 administration partagée.
F09 / R10	Une alerte de panne et une fin d'alerte visibles dans Zabbix.
NF01 / R05	Restaurer les fichiers en ≤ 240 minutes, preuve horodatée.
NF02 / R06	Dernier point effectivement restaurable âgé de ≤ 24 heures.
NF04 / R07	Capacité d'au moins 63 salariés sans renumérotation.
NF05 / R11	Flux autorisé fonctionnel, flux interdit bloqué et journalisé pour chaque zone testée.
C01/C02 / R08	CAPEX ≤ 30 000 € ; OPEX ≤ 6 000 €/an.
C05 / R12	Parcours essentiel utilisable avec lecteur d'écran.
NF03 / R13	Fichier CAO de 500 Mo transféré, empreinte vérifiée et durée mesurée ; seuil métier PENDING.

3.1 Contraintes non négociables

L'adressage Lyon, les VLAN, le domaine ad.valcrea.fr, le parc GNS3 imposé et les bornes financières du TP ne sont pas renumérotés ni modifiés. Les règles métier E05 restent une conception de flux, distincte de futures règles pfSense validées par essais E13.

4. Architecture logique et schéma réseau

Le dossier E06 VALIDATED définit un cœur Lyon pfSense FW-LYON, une distribution SW-LYON Open vSwitch (trunk 802.1Q), cinq VLAN fonctionnels, le VLAN de stationnement 999, l'accès nomade OpenVPN et deux zones cible approuvées à Bordeaux. Le raccordement intersites demeure projeté, pas déployé.

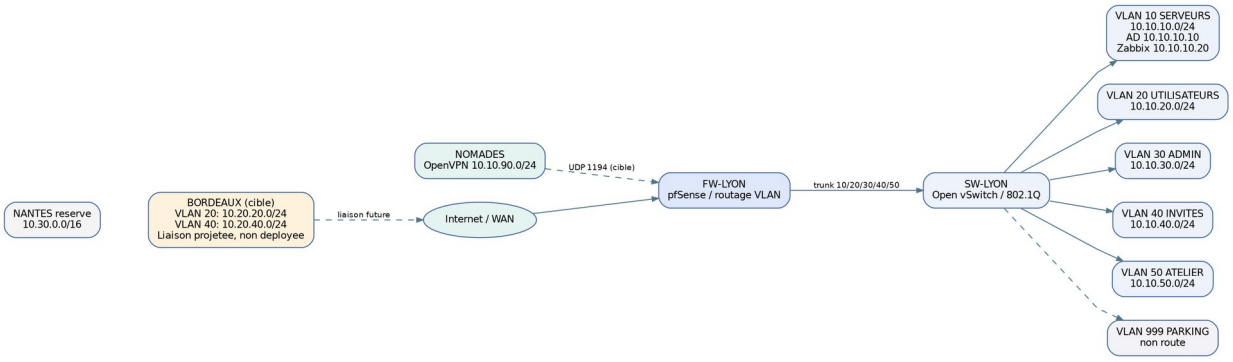


Figure 1 — Vue de synthèse reconstituée à partir des descriptions E04–E07 ; ne constitue pas l'export PNG original du schéma E06.

4.1 Frontière conception / laboratoire

Le laboratoire officiel implémente le siège Lyon uniquement ; les réseaux Bordeaux sont une architecture cible de production et Nantes une réserve. Le dessin source E06 « 2-schema-logique.drawio » est référencé sur GitHub, mais son PNG original livré au chat MAIN n'était pas disponible dans cette session. La figure ne remplace pas ce fichier graphique validé.

Le compte rendu E01 rapporte 10/10 raccordements conformes et des démarrages individuels Windows/pfSense. Cela ne prouve ni VLAN/trunk actifs, ni AD opérationnel, ni haute disponibilité.

5. Plan d’adressage et segmentation VLAN

Convention SOURCE-REQUIRED : Lyon 10.10.0.0/16, Bordeaux 10.20.0.0/16 ; troisième octet égal au VLAN, passerelle .1. Les plages ci-dessous sont tirées du plan E04, les deux zones Bordeaux ayant été explicitement acceptées par MAIN (B01/B02).

Zone / site	VLAN · réseau	GW	DHCP	DNS
Lyon SERVEURS	10 · 10.10.10.0/24	10.10.10.1	.200–.220	10.10.10.10
Lyon UTILISATEURS	20 · 10.10.20.0/24	10.10.20.1	.100–.199	10.10.10.10
Lyon ADMIN	30 · 10.10.30.0/24	10.10.30.1	.100–.149	10.10.10.10
Lyon INVITES	40 · 10.10.40.0/24	10.10.40.1	.100–.199	10.10.40.1
Lyon ATELIER	50 · 10.10.50.0/24	10.10.50.1	.100–.149	10.10.10.10
Lyon PARKING	999 · non routé	—	—	—
Bordeaux UTILISATEURS	20 · 10.20.20.0/24	10.20.20.1	.100–.199	10.10.10.10*
Bordeaux INVITES	40 · 10.20.40.0/24	10.20.40.1	.100–.199	10.20.40.1*

* Bordeaux : DNS et DHCP restent conditionnels à la conception d’exploitation B03 PENDING ; B01/B02 approuvent les zones, réseaux, passerelles et plages sans prouver le service actif.

5.1 Adresses et réserves

- SRV-AD01 : 10.10.10.10/24, GW 10.10.10.1, DNS 10.10.10.10 ; domaine ad.valcrea.fr et NetBIOS VALCREA.
- SRV-SUP01 : réservation DHCP prévue à 10.10.10.20 ; réservation effective à réaliser en E10.
- NOMADES : 10.10.90.0/24, réseau de tunnel OpenVPN (pas de VLAN Ethernet ni de passerelle arbitraire) ; allocation effective V01 PENDING.
- Nantes : 10.30.0.0/16 réservé, sans route, VLAN ni DHCP. VLAN 999 : aucun L3.

5.2 Croissance

Un /24 permet 254 adresses hôtes utilisables. Les pools utilisateurs de 100 baux à Lyon et Bordeaux couvrent le scénario de principe de +15 salariés, sans prouver le nombre de terminaux simultanés ; l’inventaire CAP01 est encore PENDING.

6. Matrice de flux et politique de sécurité

La matrice E05 comprend 51 lignes identifiées : 38 candidats ALLOW et 13 DENY. La politique cœur A01–A05 est approuvée ; les 38 ALLOW ne sont pas autant d'autorisations d'implémentation approuvées. Le principe applicable est le refus par défaut et l'ouverture minimale justifiée.

Origine	Destination / service	Décision de conception
UTILISATEURS Lyon	SRV-AD01, AD/DNS/SMB	Autoriser les seuls ports métier justifiés.
UTILISATEURS Lyon	Internet HTTPS/HTTP	Autoriser web après exclusion réseaux internes.
INVITES Lyon/Bordeaux	Internet web et DNS pfSense local	Autoriser ; bloquer accès interne et administration.
ATELIER Lyon	AD et partage Production	Autoriser selon ACL ; interdire Internet.
ADMIN Lyon	FW / serveurs ciblés	Accès nominatif restreint, pas ANY→ANY.
NOMADES	FW-LYON UDP 1194 puis DNS/SMB SRV-AD01	VPN limité, ADMIN interdit.
Zabbix	FW-LYON UDP 161 ; SRV-AD01 TCP 10050	Supervision ciblée ; contrôle pare-feu hôte.
Bordeaux UTILISATEURS	Services Lyon via liaison sécurisée future	Cible seulement, interconnexion non déployée.
WAN externe	RDP TCP 3389	INTERDIT.

6.1 Exceptions et arbitrages non approuvés

Restent PROPOSED/PENDING : RPC AD dynamique TCP 135/49152–65535 (ex. F17/F18/F43), RDP interne depuis ADMIN (F21), mises à jour sortantes insuffisamment bornées (F42), Zabbix agent actif TCP 10051 (F39), SSH/HTTPS de gestion non inventoriés et nouveaux flux intersites. Leurs mentions ne constituent pas une permission de configuration.

6.2 Méthode de recette

E13 doit traduire les autorisations approuvées en règles ordonnées, journaliser les blocages utiles, vérifier la règle anti-verrouillage ADMIN et retirer l'ouverture temporaire SERVEURS. E17 devra tester les perspectives ADMIN, INVITES et WAN et produire des preuves d'autorisation/refus. Aucune de ces opérations n'a été réalisée lors de la conception.

7. Services, résilience, sauvegarde et évolutivité

E07 couvre sept services. Les affectations du laboratoire sont des prescriptions et non des attestations de disponibilité ; l'architecture renforcée E07-P1 à P5 reste PROPOSED.

Service	Hébergement / ports	Continuité et vérification attendue
DHCP	pfSense Lyon, UDP 67/68	Étendues E04 ; relais/hébergement Bordeaux B03 PENDING.
DNS	AD Lyon TCP/UDP 53 ; invités DNS local	Second DNS Bordeaux P1 PROPOSED ; test résolution.
Active Directory	SRV-AD01, Kerberos/LDAP/GC selon besoin	P1 deuxième DC et réplication proposées, non installées.
Fichiers	SRV-AD01, SMB TCP 445	ACL AGDLP/NTFS ; backup + PRA et RTO/RPO à tester.
Supervision	SRV-SUP01 Zabbix, SNMP 161 / agent 10050	Alertes et résolution à démontrer en E16.
Accès distant	FW-LYON OpenVPN UDP 1194	Nomades limités ; intersite IPsec proposé, non actif.
Sauvegarde	NAS local + hors site proposés	Règle 3-2-1, intégrité, rétention et restauration à prouver.

7.1 Options E07

ID	Option	Statut / limite
P1	Second DC/DNS Bordeaux	PROPOSED ; ne duplique pas automatiquement les fichiers.
P2	Paire firewall CARP Lyon	PROPOSED ; IP physiques et VIP .1 à arbitrer.
P3	4G + UPS	PROPOSED ; couverture/autonomie et bascule à tester.
P4	Backup 3-2-1 et PRA	PROPOSED ; protection ransomware, rétention et restauration non prouvées.
P5	DHCP local Bordeaux	PROPOSED ; B03 doit préciser continuité et hébergement.

7.2 Capacité de reprise

RTO 240 min et RPO 24 h concernent les fichiers. Il existe ~1,2 To utilisés selon l'existant. Mesurer le temps complet de restauration des partages, droits et accès ; sauvegardes quotidiennes réussies et point sain restaurable sont indispensables. Ni RAID, ni second contrôleur AD, ni achat de stockage ne prouvent seuls ces objectifs.

8. Budget CAPEX/OPEX/TCO sur cinq ans

Les montants sont tirés du catalogue fictif TP01, Annexe B p.17–18, avec quantités E08 PROPOSED. Tous les prix sont HT. Les abonnements mensuels sont multipliés par 12 ; le TCO repose sur cinq exercices à tarifs constants.

Mesure	Scénario A – socle	Scénario B – renforcé
CAPEX	21 650 €	27 400 €
OPEX annuel	3 276 €	4 296 €
TCO 5 ans	38 030 €	48 880 €
Marge CAPEX / 30 000 €	8 350 €	2 600 €
Marge OPEX / 6 000 €	2 724 €/an	1 704 €/an

8.1 Composition du scénario A

Poste	Quantité	CAPEX HT	OPEX HT/an
Pare-feu PF-M Lyon + PF-S Bordeaux	1 + 1	2 140 €	360 € support
Switches SW-24P + SW-24 + SW-8P	1 + 2 + 1	2 870 €	—
Wi-Fi AP-6	3	780 €	—
Serveur SRV-R	1	6 900 €	420 € garantie
NAS-4	1	1 850 €	—
UPS-15 + UPS-7	1 + 1	1 070 €	—
Windows LIC-WS + CAL-5	1 + 13 packs	4 090 €	—
INT	3 journées	1 950 €	—
FIB-L + FIB-B + SAV-C	1 de chaque	—	2 496 €
TOTAL	—	21 650 €	3 276 €

Les 13 packs de cinq CAL assurent un dimensionnement théorique de 65 utilisateurs pour 63 salariés ; conditions de licence à vérifier. B ajoute second PF-M, SRV-T Bordeaux + LIC-WS, 4G, supports associés et deux journées INT, soit +5 750 € CAPEX et +1 020 € OPEX/an.

TCO A = 21 650 + 5 × 3 276 = 38 030 € ; TCO B = 27 400 + 5 × 4 296 = 48 880 €. Le scénario A est la référence financière recommandée, sans autorisation d’achat.

9. Limites, hypothèses et points restant à valider

Sujet	État	Effet sur la conception
V01	PENDING	Pool et extrémité OpenVPN réels à définir en E14.
B03	PENDING	DHCP/DNS Bordeaux et continuité en cas de rupture de liaison.
CAP01	PENDING	Inventaire terminaux, invités, ports PoE, AP et dimensionnement.
NF03/R13	PENDING	Seuil métier maximal de transfert CAO 500 Mo.
E05 exceptions	Non approuvées	Aucune autorisation supplémentaire automatique en E13.
E07 P1–P5	PROPOSED	Pas de HA ou de nouveaux services réputés acquis.
E08 quantités et achats	PROPOSED	Aucun bon de commande ni accord fournisseur.

9.1 Coûts non valorisés

Électricité effective, équipements de baie/installation, évolution des abonnements, renouvellement matériel pendant cinq ans, prestations hors catalogue, maintenance switch/AP, transport et capacité réelle de backup, stockage immuable/hors ligne et exploitation humaine restent non chiffrés. Le repère du support p.22 est 1 W permanent = 8,76 kWh/an ; sans puissance vérifiée des actifs, aucun montant global fiable n’est ajouté.

9.2 Dépendances majeures

- La liaison Bordeaux–Lyon est une cible, pas un tunnel démontré ; perdre cette liaison peut rendre DNS/AD Lyon inaccessibles depuis Bordeaux.
- La haute disponibilité de l’authentification n’implique pas la haute disponibilité du service fichiers.
- Les protections de sauvegarde contre le ransomware et le rétablissement en quatre heures restent à démontrer par test.
- Les captures E01 et le snapshot GNS3 demandé p.8 ne sont pas vérifiés ici.
- Le PNG original E06 n’est pas accessible pour vérification/inscription fidèle ; voir la figure reconstituée p. architecture.

10. Conclusion et stratégie de déploiement

Le projet propose une segmentation en zones et un filtrage de moindre privilège pour supprimer les principaux chemins d'attaque de l'existant. Il distingue la cible multi-sites du laboratoire Lyon exigé par le TP. Les identités, la confidentialité RH, les fichiers CAO, la supervision et la sauvegarde forment un ensemble cohérent avec la croissance à 63 utilisateurs, sous réserve des contrôles restant ouverts.

10.1 Trajectoire recommandée

Phase	Travail	Preuve requise
Partie 1 / E08	Soumettre le socle financier A, les arbitrages et le dossier	Validation par MAIN ; aucune acquisition implicite.
Partie 2 / E09–E10	Configurer OVS VLAN/trunk puis pfSense interfaces/DHCP/DNS	Sorties ovs-vsctl, DHCP, routes et captures.
Partie 2 / E11–E13	Activer AD, droits AGDLP et règles pfSense	Tests DNS, SMB/NTFS, flux autorisés/refusés.
Partie 3 / E14–E16	OpenVPN, durcissement, supervision	VPN sans ADMIN, stratégies, événements et alertes.
Partie 3 / E17–E19	Audit Nmap, correction, dossier technique final	Scans, contre-tests, sauvegardes, preuves et archive.

10.2 Recommandation de synthèse

Le scénario A respecte les plafonds sur les postes chiffrés et conserve davantage de marge. Les achats complémentaires du scénario B sont conditionnés à l'inventaire, à la disponibilité opérationnelle réellement nécessaire et à l'essai PRA. Pour les 1,2 To de données existantes, un RTO de quatre heures n'est plausible que si le scénario de restauration complet, les performances et les responsabilités sont établis et testés ; les éléments actuels ne permettent pas de conclure favorablement.

Décision finale : MAIN PROGRESSION. Aucune modification des décisions D01–D12, A01–A05 et B01/B02, ni conversion des PENDING en APPROVED.

Annexe A. Traçabilité de l'audit et de la conception

Étape	Livrable / référence	Utilisation dans ce dossier
E02	Audit validé, 20 constats (12 T, 8 O)	Synthèse des sept risques majeurs ; grille complète non reproduite.
E03	E03_CAHIER_DES_CHARGES.md	24 exigences et 13 critères de recette, chap. 3.
E04	E04_PLAN_ADRESSAGE.md et .csv	Plages, capacités, B01/B02 et statut, chap. 5.
E05	E05_MATRICE_FLUX.csv ; E05_POLITIQUE_ACCES.md	51 lignes (38 ALLOW, 13 DENY), politique cœur, chap. 6.
E06	2-schema-logique.drawio ; PNG remis à MAIN	Topologie et périmètre, chap. 4 ; PNG non accessible ici.
E07	E07_SERVICES_RESILIENCE.md	Sept services, RTO/RPO, options P1–P5, chap. 7.
E08	E08_BUDGET.csv ; E08_BUDGET_ANALYSE.md	Montants, hypothèses, scénarios et limites, chap. 8.

Sources pédagogiques

- TP-01-projet-reseau-securise-valcrea.pdf : p.2–8 (topologie, cahier, segmentation, flux, résilience, budget), Annexe A p.16–17, Annexe B p.17–18, Annexe C p.18–19.
- Support de Formation — Conception d'un réseau sécurisé pour une PME.pdf : p.7–14 (besoins, topologie, services, résilience, budget), p.22 (énergie), p.26 (documentation).
- GitHub : CwithLove/concept_admin_secu_reseau, branche main, E08/MAIN_STATE.md et E08/DECISIONS.md v1.9.0.

La validation E08 v1.9.0 concerne l'état canonique lu ; la présente compilation doit encore recevoir la validation propre à ce livrable de MAIN PROGRESSION.

Annexe B. Registre opérationnel compact

Contrôle	Cible / preuve	Statut actuel
VLAN 10/20/30/40/50 et 999	Trunk/access et parking OVS E09	NOT_TESTED
Routage/DHCP/DNS Lyon	Paramètres pfSense E10	NOT_TESTED
AD et DNS	ad.valcrea.fr + résolution E11	NOT_TESTED
Droits RH / Production	AGDLP et tests SMB E12	NOT_TESTED
Filtrage E05	Test invité/atelier/VPN/WAN E13–E14	NOT_TESTED
Zabbix	SNMP/agent, alerte et résolution E16	NOT_TESTED
PRA fichiers	RTO ≤240 min et RPO ≤24 h	NOT_TESTED
Budget A/B	Calculs et catalogue Annexe B	PASS documentaire
GNS3 E01	10/10 ports + boots individuels	OBSERVED-REPORTED E01
Snapshot GNS3	Capture gestionnaire et horodatage	NOT_TESTED

Note de conformité

Le TP exige la présence de la grille d'audit, du cahier des charges, du plan d'adressage, de la matrice de flux, des services, des choix de résilience et du budget dans 1-conception.pdf. Ces rubriques sont présentées sous forme synthétique. Les 20 constats E02 et les 51 lignes E05 ne sont pas reproduits exhaustivement dans ce PDF ; ils restent référencés dans les sources. L'original du PNG E06 n'a pas été inséré. Ces deux limites imposent une revue MAIN avant qualification du dossier comme version finale de soumission.